UNITÀ 1 · LEZIONE 3 · ATTACCANTI: I CYBERCRIMINALI

Anatomia di un attacco vero

Smonta un attacco documentato come un analista di threat intelligence: chi, perché, in quali fasi, con quali tecniche, dove si poteva fermare.

Cosa consegni: un file **attacco-cognome.pdf** (2-3 pagine) su Novaula, nella scheda Compiti.
Scadenza: quella indicata su Novaula.

Scegli un caso

WannaCry (2017) · NotPetya (2017) · SolarWinds (2020) · Colonial Pipeline (2021) · l'attacco ransomware alla Regione Lazio (2021) · un altro caso documentato, concordato con il docente.

Che cosa devi fare

1. Trova almeno **3 fonti** affidabili (agenzie e aziende di sicurezza, giornali seri; Wikipedia solo come punto di partenza). Per ognuna annota titolo, sito e data.
2. **Profilo dell'attaccante**: tipo (criminale, statale, hacktivista…), motivazione, a chi è stato attribuito e da chi. Distingui i fatti certi dalle attribuzioni.
3. **Kill chain**: una tabella con le 7 fasi e, per ciascuna, che cosa è successo (scrivi "non noto" se le fonti non lo dicono).
4. **MITRE ATT&CK**: almeno **5 tecniche** con codice, nome e tattica, verificate su attack.mitre.org.
5. **Impatto**: quali principi CIA sono stati colpiti, chi ha subito danni, per quanto tempo.
6. **Lezione per la difesa**: le 2 contromisure che, secondo te, avrebbero fermato l'attacco il prima possibile, con il motivo.

Esempio di riga ATT&CK

Tattica	Tecnica	Che cosa è successo nel caso
Initial Access	T1190 Exploit Public-Facing Application	Sfruttata una falla di un servizio esposto su Internet non aggiornato

> *"Il fattore umano è davvero l'anello più debole della sicurezza."* · **Kevin Mitnick**, *L'arte dell'inganno, 2002 (traduzione nostra).*

Come viene valutato

Criterio	Punti
Fonti affidabili e citate; fatti distinti dalle attribuzioni	2
Profilo dell'attaccante e motivazione	1
Kill chain completa e coerente	2
5 tecniche ATT&CK corrette con codice e tattica	3
Impatto e contromisure motivate	2

Si studiano casi pubblici per difendersi. Non scaricare né eseguire campioni di malware e non visitare siti di "leak" dei gruppi criminali: bastano le fonti giornalistiche e tecniche.